

Controls & Compliance Checklist

Representative control assessment, evidence expectations, risk rating, and remediation plan

Assessment approach. Review the control objective, identify expected evidence, document the observed gap, estimate risk from likelihood and business impact, assign an accountable owner, and define remediation. This portfolio work sample demonstrates analyst methodology; it is not a formal audit opinion.

1. Control Assessment

Domain	Control objective	Expected evidence	Representative gap / risk	Rating	Recommended remediation
Identity & Access	Enforce least privilege and periodic access review.	Access listings, approvals, review records, termination workflow.	Privileged accounts lack quarterly review evidence.	High	Run quarterly privileged-access reviews; remove excess rights; retain approval and review evidence.
MFA	Require strong authentication for privileged and remote access.	MFA policy, IdP settings, enrollment report.	Legacy remote-access path permits password-only authentication.	Critical	Require MFA, disable legacy authentication, and validate conditional-access coverage.
Logging & Monitoring	Centrally log and review security-relevant events.	SIEM sources, retention settings, alert rules, review records.	Key administrative activity is not forwarded to the central logging platform.	High	Onboard required log sources; validate parsing, retention, alerting, and review ownership.
Vulnerability Mgmt	Identify, prioritize, remediate, and validate vulnerabilities.	Scan reports, asset inventory, tickets, SLAs, validation evidence.	Critical findings are not consistently tied to owners and due dates.	High	Risk-rank findings, assign owners, enforce remediation SLAs, and document validation.
Patch Mgmt	Apply security updates according to risk.	Patch dashboards, change records, exception list.	Internet-facing systems show inconsistent patch compliance.	High	Establish risk-based patch SLAs; remediate exposure; report overdue systems.
Backups & Recovery	Protect backups and test recovery.	Backup logs, restore tests, RTO/RPO records.	Restore testing is not consistently documented.	Medium	Schedule recovery tests; record results, exceptions, owners, and corrective actions.
Incident Response	Maintain tested procedures for security incidents.	IR plan, playbooks, contact list, exercise results.	Escalation and communications steps are not consistently exercised.	High	Run tabletop exercises; update playbooks; document lessons learned and assigned actions.
Data Protection	Protect sensitive data at rest and in transit.	Encryption settings, key controls, data classification, exceptions.	Encryption evidence is incomplete for selected sensitive-data flows.	High	Validate encryption coverage; document key management; remediate or formally approve exceptions.

2. Risk Rating Guide

Rating	Interpretation	Typical response
Critical	Immediate or highly probable material exposure.	Immediate containment or remediation; executive visibility as appropriate.
High	Significant control weakness or exposure requiring priority action.	Assign owner and near-term due date; track through closure.
Medium	Meaningful weakness with lower likelihood, scope, or compensating controls.	Remediate through planned work and monitor exceptions.
Low	Limited exposure or improvement opportunity.	Track through normal operations.

3. Evidence Quality Checklist

- Evidence is current, attributable to the correct system or control, and covers the assessment period.
- Evidence demonstrates operation of the control, not only the existence of a policy.
- Exceptions are documented with owner, rationale, compensating controls, approval, and expiration date.
- Remediation tickets include accountable owners, due dates, status, and validation evidence.
- Conclusions distinguish verified facts from assumptions or items still requiring confirmation.

4. Framework Mapping

Control area	Relevant framework examples
Identity / MFA	NIST CSF Protect; NIST SP 800-53 AC/IA; CIS Controls 5 and 6; ISO/IEC 27001 access-control themes
Logging / Monitoring	NIST CSF Detect; NIST SP 800-53 AU/SI; CIS Control 8; ISO/IEC 27001 logging/monitoring themes
Vulnerability / Patch	NIST CSF Identify/Protect; NIST SP 800-53 RA/SI; CIS Controls 4 and 7
Backups / Recovery	NIST CSF Recover; NIST SP 800-53 CP; CIS Control 11
Incident Response	NIST CSF Respond; NIST SP 800-53 IR; CIS Control 17
Data Protection	NIST CSF Protect; NIST SP 800-53 SC; CIS Control 3

5. Analyst Deliverable

- Summarize the highest-risk gaps first and explain the business consequence in plain language.
- Separate immediate containment from long-term corrective action.
- Assign every remediation item to an accountable owner with a target date.
- Retest or review evidence before closing a finding.
- Preserve an audit trail of evidence, decisions, exceptions, and validation.